

CONTINUATION — Helix

Proxy: VPN-Aware Dynamic Routing Extension

Revision: 7 **Last modified:** 2026-07-01T14:52:00Z **Status:** Active — **§11.4.126 autonomous hardening loop** (operator: "keep hardening, don't tag yet"). **P10 VPN fail-closed = GREEN:** dynamic stack booted, tunnel DOWN → branded 503 ERR_TUNNEL_DOWN ×3, leak_seen=0, Squid PID unchanged, deterministic ×3 + RED-polarity; egress-half operator-gated SKIP (§11.4.21). **2 security fixes landed + VERIFIED DEPLOYED LIVE** (§11.4.108 runtime-signature): Squid header/version-hygiene (via off+forwarded_for delete+version-suppression — Via gone) 4f983ee; Dante SOCKS5 SSRF (block link-local/loopback/RFC1918 + command:connect) 4626f05. **Rev-7 hardening wave (5 commits):** 790c191 **S4 SSRF guard hardened** — the SOCKS-block verdict now requires dante's authoritative block(N) log line (§11.4.69), NOT elapsed-time (an independent §11.4.142 review found the timing-only discriminator bluff-capable on fast-refuse hosts); **security guard now WIRED into the standing suite** (run-tests.sh test_security_guards, §11.4.135, GREEN+RED-polarity, set-e-safe) — iterate-to-GO (§11.4.134); 487c918 **cache challenge authoritative** — reads Squid's own access.log via podman exec → real TCP_MEM_HIT (§11.4.69), no more SKIP-fallback (Squid caching proven genuine); 3755702 **control-plane unit coverage** store 64.5→98.2% / vpn 78.6→98.1% / api 69.6→80.3% / healthd 61.3→67.6% (real error/fail-closed branches, race-clean, go.sum unchanged); 86126ac README §11.4.57 doc-link section; ad720ec this file → Rev 6. **2 items TRACKED-for-operator** (connectivity-risk §11.4.101): Squid dns_nameservers DNS-leak (static mode); Dante client-side open-relay. **§11.4.169 matrix = 9 PASS / 2 honest SKIP** (docs/design/hardening/Status.md Rev 3). **LE issuance + renewal BOTH PROVEN** — autonomous scope COMPLETE; Phase 4/6 OPERATOR-BLOCKED (§11.4.10). HEAD 790c191 (== main == github/origin/upstream). **Branch:** feature/vpn-aware-dynamic-routing **Spec:** docs/superpowers/specs/2026-06-30-vpn-aware-proxy-extension-design.md (Rev 4) **Plan:** docs/superpowers/plans/2026-06-30-vpn-aware-proxy-extension-plan.md (Rev 1) **Authority:** Inherits the Helix Constitution submodule (constitution/Constitution.md) per §11.4.35.

§12.10 live-state resume file. Read this first, then `git fetch --all --prune` and re-read `git log --oneline main..HEAD`. Any agent must be able to resume exactly where the last session left off from this single file.

1. Current PHASE

§11.4.126 autonomous hardening loop — construction (P0-P10 fail-closed) is landed; the loop is now closing hardening gaps under all §11.4.169 test types with real captured evidence.

Operator decision in force: **"keep hardening, don't tag yet."**

The Go control-plane (stores, health-publisher, acl-helper, config-compiler, P5b breaker/failover, P6 control-API/SSE/metrics/PAC/mTLS) builds + vets + gofmt-clean and is proven unit / integration / config-parse; the dynamic compose profile boots live and the **fail-closed data-plane proof is GREEN**. Base proxy UP on :53128 (204); host ~43%; 4 helixproxy_* Podman secrets present (enable dynamic re-boot).

P10 VPN fail-closed — GREEN (§11.4.68/.115/.108): tests/dynamic/vpn_failclosed_test.sh proven live — booted the dynamic stack, forced the tunnel DOWN via Redis `vpn:status`, tunnel-DOWN ⇒ branded 503 ERR_TUNNEL_DOWN ×3 (real 3132-byte page), leak_seen=0, Squid PID unchanged; deterministic ×3 (§11.4.50) + RED polarity guard FAILs a fabricated 200 leak (§11.4.115). Real-VPN-egress half is operator-gated SKIP (gluetun WireGuard creds §11.4.21). Evidence qa-results/dynamic/vpn_failclosed/20260701T130115Z/. Re-runnable boot recipe: 4 external Podman secrets from tests/observability/gen_test_mtls.sh → `./start --dynamic` (backgrounded) → poll proxy-squid Up + compiler renders `dynamic-routing.squid` → `HELIX_DYNAMIC_STACK=1 GOMAXPROCS=2 nice -n 19 ionice -c 3 bash tests/dynamic/vpn_failclosed_test.sh`; restore base after: `./stop && ./start`.

2 real security fixes (config-security review, docs/design/security/Status.md Rev 2) — RED→GREEN + sink-side evidence + standing guards:

- Squid header/version-hygiene (4f983ee): via `off + forwarded_for delete + httpd_suppress_version_string on + visible_hostname helix-proxy` in `squid.conf` + `squid.dynamic.conf`. The Via: 1.1 proxy-squid (squid/6.13) leak was CONFIRMED live (RED) → GONE (GREEN). Guard: `proxy_acl_security.sh` S3. **Root-cause note:** single-file :ro bind mounts pin the inode → config edits need a container **recreate** (`./stop && ./start`), NOT `squid -k reconfigure` (re-reads the stale inode).
- Dante SOCKS5 SSRF (4626f05): command: `connect + socks block` for 127/8, 169.254/16, 10/8, 172.16/12, 192.168/16 in `sockd.conf`. 5 internal targets refused fast (code 000 ~0.01s,

dante-log block(N)), external control 204, no public-egress regression. Guard: proxy_acl_security.sh S4.

2 items TRACKED-for-operator (§11.4.101 connectivity-risk, NOT autonomously fixed): (1) Squid dns_nameservers 8.8.8.8 bypasses the DoT dnsproxy → DNS leak in **static** mode (dynamic mitigated by never_direct); re-point = risk. (2) Dante socksmethod none + client pass from:0.0.0.0/0 open-relay if :51080 escapes the bridge; client-CIDR restriction = risk. O(1) table in docs/design/security/Status.md.

§11.4.169 hardening matrix (docs/design/hardening/Status.md Rev 3) — 9 PASS / 2 honest SKIP: PASS = stress+chaos, DDoS(300/300), concurrency(40, crosstalk=0), memory(ratio 1.0017), **P10 fail-closed, race/deadlock (0 DATA RACE, 11 pkgs), benchmark (200/200, p50=86ms/p95=88ms/p99=91ms, 10.84 req/s)** + unit/integration. SKIP (honest §11.4.3) = security ACL live-deny (no autonomous deny topology) + P10 egress-half (gluetun creds).

Remaining actionable (non-operator-gated) is thinning. Operator-gated: 2 TRACKED security items (connectivity risk), LE Phase 4/6, P10 real-egress (gluetun creds), HelixQA vendoring (6 un-vendored siblings), release tag.

2. Landed commits (newest first)

main FF-tracks HEAD (§11.4.113 FF-only), so main..HEAD is empty — HEAD == main == github/origin/upstream == 790c191. The full feature-branch history since the original branch point is below; the historical table (numbered 1-28) is retained for the earlier construction wave.

Latest hardening wave (newest first):

Commit	Lane	Summary
790c191	security	S4 SSRF guard → authoritative dante block(N) log-line discriminator (§11.4.69) + security guard wired into standing suite (§11.4.135) — independent-review-driven (§11.4.142/.134)
487c918	challenge	proxy cache challenge → authoritative TCP_*HIT via container access.log (§11.4.69), no more SKIP-fallback (Squid caching proven genuine)
3755702	control-plane	unit coverage store 64.5→98.2% / vpn 78.6→98.1% / api 69.6→80.3% / healthd 61.3→67.6% (real error/fail-closed branches, race-clean)

Commit	Lane	Summary
86126ac	docs	README §11.4.57 Tracked-Items doc-link section (9 Status docs)
ad720ec	docs	CONTINUATION → Rev 6 (§12.10 sync: P10 GREEN + security fixes + §11.4.169 matrix)
4626f05	security	Dante SOCKS5 SSRF hardening — block internal/link-local/loopback egress + <code>command:connect</code> (RED→GREEN + S4 guard)
4d0a7ed	control-plane	drop dead nil-check in <code>TestPostgresSatisfiesQueries</code> (golangci SA4023)
916e72b	helixqa	unblock recipe for the proxy test bank (6 un-vendored own-org siblings)
8833ccc	letsencrypt	cert-analyzer edge-case coverage 37→55 (validity boundaries, malformed PEM, empty/IP/mixed SAN, double-wildcard)
4f983ee	security	Squid header/version-hygiene hardening (via <code>off</code> + <code>forwarded_for</code> delete + version suppression) — RED→GREEN + S3 guard
1caaf51	hardening	control-plane unit(100-61%)+Go-benchmarks+audit-atomicity-verified + Challenges 2/3 + §11.4.169 matrix sync
567c9e1	hardening	P10 VPN fail-closed GREEN + <code>race(0)/benchmark(p50=86ms)</code> + §11.4.169 Status matrix

Earlier construction wave (historical, numbered from the original branch point):

#	Commit	Phase	Summary
28	8d95f8a	P6	real bidirectional metric-name drift guard (§1.1-mutation-proven) + concurrency consistency test; WARNING-3/4/5
27	2bc03de	BUGFIX-0006	revive + de-bluff comprehensive-test.sh ((()) abort = 100% dead) + real B2/B3/B8 evidence; surfaced regression #50
26	4394643	BUGFIX-0005	final-verify.sh + verify-proxy.sh no longer green a NO-VPN config (false-VPN-routing §15) + <code>set -e</code> abort
25	cd11494	BUGFIX-0004	run-tests.sh no longer FAILs a healthy proxy — §11.4.3

#	Commit	Phase	Summary
			topology-aware ports + 3-state SKIP
24	6a8f886	P11	refresh CONTINUATION to live state (Rev 2) — 23 commits, P5b/P6/BUGFIX-0002/0003 landed, P8 in flight
23	61b4215	chore	gofmt-format 6 pre-existing files (formatters-clean mandate; semantics-null verified)
22	62b22fe	P6	control-API server (REST/SSE/metrics/PAC, fail-closed mTLS) + coherent operator-wiring contract
21	1045dfd	BUGFIX-0003	test_result must return 0 — suite no longer aborts mid-run under set -e
20	c6f2935	P9	§11.4.18 operator-guide companions for the 16 tests/dynamic scripts
19	b5573a9	BUGFIX-0002	squid log-dir writable under rootless Podman (proxy crash-loop) — existing features now serve live
18	0aca034	P9	anti-bluff dynamic-routing test/analyzer harness (tests/dynamic)
17	e6e93ec	P10-prep	dynamic compose profile + control-plane/squid Containerfiles + orchestrator wiring
16	6bdeef9	P5b	circuit-breaker + tier-failover (internal/breaker, gobreaker/v2)
15	7d0d128	P11	CONTINUATION (§12.10) + spec §9 reconcile + §11.4.65 HTML/PDF export backfill
14	1833c8f	P7.3	per-user Squid auth + rootless Podman-secret loader + kill-switch design (no secrets)
13	603e039	P5a	acl-helper — Squid external_acl OK/ERR from Redis, fail-closed (stdlib)
12	e6e336f	P7.1	per-tunnel DoH/DoT (dnsproxy) config plan + DNS-leak test design
11	04526dd	P4	

#	Commit	Phase	Summary
			config-compiler — render Squid/Dante/PAC from PG + seed route keys (parse-verified)
10	833fb9e	P7.2	Prometheus scrape + Grafana dashboard config plan (promtool-validated)
9	11106a4	P3	vpn-health-publisher (cmd/healthd + internal/vpn) — data-plane health, fail-closed, TDD
8	b66d172	P4	Squid 6.13 + Dante dynamic-mode templates (additive, parse-verified) + spec reconcile
7	fbfe9ed	P1	docs(spec): mark §20 gaps G1-G4 RESOLVED with spike decisions
6	e19e0ed	P2	store (pgx) + redis (go-redis) clients — fail-closed, TDD, real PG/Redis
5	6409cb9	P1	docs(research): resolve spec §20 gaps G1-G4 with captured-evidence spikes
4	6802798	P1/E	docs(audit): §11.4.138 forensic bluff-audit of 4 existing test scripts (8 bluffs)
3	9ac1b4a	P0	docs(dynamic-routing): DYNAMIC_ROUTING.md + 2 mermaid diagrams
2	6251007	P0	chore(submodules): incorporate containers, helix_qa, challenges, docs_chain (SSH, no-force)
1	5f917a7	P0	P0 scaffold — data model, evidence harness, Go skeleton, governance carriers

3. PROVEN-NOW vs OWED-TO-P10 (honest §11.4.6)

PROVEN-NOW (control-plane / config-plane / spike facts — captured)

- **Existing proxy serves LIVE (BUGFIX-0002)** — after the rootless-Podman log-dir fix, the booted --no-vpn stack proves all 3 existing features: HTTP forward proxy 200 + Via: 1.1 proxy-squid, Dante SOCKS5 200, squid cache TCP_MEM_HIT (no origin contact). Guard: tests/regression/

log_dir_writable_test.sh (§11.4.115 polarity, §1.1 mutation byte-identical md5 0128a96b6d467c2da5b7cef8a808e563). Evidence: qa-results/regression/bugfix38/.

- **P5b breaker/failover** (internal/breaker, gobreaker/v2) — per-target circuit breaker + tunnel tier-failover, TDD.
- **P6 control-API** (cmd/api + internal/api + internal/pac) — REST CRUD + SSE + Prometheus /metrics + PAC, **fail-closed mTLS** (RequireAndVerifyClientCert), coherent operator-wiring contract (CONTROL_API_TLS_CERT/_KEY/_TLS_CLIENT_CA, :58080); builds + vets clean, §1.1 mutation md5 67125c7a1ab9b00c98fb164f765b04af.
- **Spec §20 gaps G1-G4 resolved** with transient-spike captured evidence (docs/research/mvp/findings/F_spikes_G1-G4.md, run-id qa-results/spikes/20260630_205029_glg4/): G2 ubuntu/squid:latest = Squid **6.13** (not v8), §8 directive set squid -k parse exit 0; G4 gluetun **v3.40 (=v3.40.4)** control-API :8000 answers 200, issue #3060 confirmed; G1 kernel-WG interface **creatable rootless** with --cap-add NET_ADMIN; G3 Dante **SIGHUP preserves an active SOCKS session** (20/20 chunks, curl exit 0, /proc/net/tcp ESTABLISHED proof).
- **P2 stores** (pgx + go-redis) — fail-closed, TDD, exercised against **real PG / Redis**.
- **P3 vpn-health-publisher** (cmd/healthd + internal/vpn) — data-plane health poll → Redis state, fail-closed, TDD.
- **P4 config-compiler + templates** — Squid 6.13 (%>ha{Host}) + Dante (concatenation, no include) render from PG; **squid -k parse exit 0**; PAC + route-key seeding parse-verified.
- **P5a acl-helper** — Squid external_acl OK/ERR from Redis, **fail-closed**, stdlib-only.
- **P7.2 observability** config plan — **promtool-validated** Prometheus scrape + Grafana dashboard.
- **P7.1 DNS / P7.3 security** — config plans only (DoH/DoT per-tunnel; per-user auth + Podman-secret loader + in-netns kill-switch). Design + parse layer.
- **Existing-test bluff audit** (Stream E) — 8 bluffs across 4 scripts catalogued (§11.4.138), guards owed to P8.

CAPTURED-AT-P10 (fail-closed data-plane proof — the dynamic stack HAS booted)

The dynamic compose profile (postgres + redis + control-plane + squid+helper + dante) now **boots live**; the fail-closed half of the usability proof is captured:

- graceful_503 — **PROVEN**: tunnel DOWN (Redis vpn:status) → branded 503 ERR_TUNNEL_DOWN ×3 (3132-byte page) with **Squid PID unchanged**; deterministic ×3 + RED-polarity guard. Evidence qa-results/dynamic/vpn_failclosed/20260701T130115Z/.
- no_leak (tunnel-down case) — **PROVEN**: leak_seen=0 during the DOWN window (no target reached while the tunnel is down).

OWED-TO-P10 (real-VPN-egress half — operator-gated on gluetun WG creds)

Requires real gluetun WireGuard credentials (§11.4.21); still **unproven live**:

- `vpn_real_egress` — egress IP via proxy
== `tunnel exit && != host IP + wg transfer Δ` (200 OK is not routing).
- `no_leak` / `killswitch` (up→drop case) — drop a *real* tunnel → **zero** target packets on the real uplink (tcpdump) + DNS only via the intended resolver.
- per-user **407 auth challenge** live; **secret injection leak-free** at runtime.
- **G1 residual** — full rootless kernel-WG *operation* (handshake + routing + throughput), only interface *creation* was spiked (§20 G1).
- **G3 residual** / **P9** — concurrent / repeated SIGHUP + **route-change-mid-session** SOCKS path behaviour (§20 G3).
- circuit-breaker open → failover to next up tier — **landed** (6bdeef9, P5b); live-under-load failover proof still owed.

4. Remaining phases

Phase	Scope	State
P5b	per-target circuit breaker + tunnel tier-failover (sony/gobreaker/v2)	✓ landed 6bdeef9
P6	control-API + SSE + metrics + PAC + fail-closed mTLS	✓ landed 62b22fe (admin-UI templ/htmx + §11.4.170 host-rendered pixel proof = P6.2, deferred)
P8	fix existing-test bluffs → §11.4.3 topology dispatch / honest SKIP / §11.4.161 + §11.4.135 guards	✓ landed (cd11494/4394643/2bc03de/8d95f8a)
P9	full test matrix + Challenges + HelixQA (all §11.4.169 types; G3 route-change-mid-session live test)	§11.4.169 matrix GREEN (9 PASS/2 SKIP); Challenges 2/3; HelixQA vendoring operator-gated (6 siblings)
P10	live dynamic-mode boot + captured data-plane evidence = the usability proof	✓ fail-closed half GREEN (567c9e1); real-egress half operator-gated (gluetun WG creds §11.4.21)

Phase	Scope	State
P11	docs sync + HTML/PDF (+DOCX where mandated) exports (this CONTINUATION + .remember are part of it)	ongoing (this Rev 6 sync)
P12	whole-branch review (iterate- to-GO) + full retest + merge to main no-force + prefixed release tag	operator-gated — "keep hardening, don't tag yet"

5. Binding constraints (non-negotiable)

- **Anti-bluff §11.4** — every PASS carries positive captured **data-plane** evidence; control-plane/config-parse green is necessary, never sufficient; the end-user-usability bar is met only at P10.
- **No force-push §11.4.113** — merge onto latest main, fast-forward only; force-push is forbidden with no exception.
- **Rootless Podman §11.4.161** — all containers rootless; no Docker-rootful, no sudo, no root escalation; orchestrate via the containers submodule (§11.4.76), build on the remote host (§11.4.173).
- **Secrets-as-names-only §11.4.10** — VPN creds / proxy-auth / mTLS keys via Podman secrets / file refs; **never** plaintext in git; .env.example documents refs only.
- **Operator-safe §11.4.174** — do **NOT** touch the operator's pre-existing resources: the host wg0-mullvad (UP kernel-WG) interface and any lava-* containers (e.g. lava-postgres-thinker) are off-limits; verify process/resource ownership before acting; block-don't-break on shared-host contention.
- **Host safety §12** — ≤60% memory (§12.6); no host power-state commands (CONST-033); pull images sequentially; --rm diagnostics; df first.

6. Resume now (next actionable)

1. git fetch --all --prune on feature/vpn-aware-dynamic-routing; confirm HEAD 790c191 (== main == all 3 remotes github/origin/upstream; integrate any newer foreign commit per §11.4.71, no force §11.4.113). The single canonical moment-valid resume file is .remember/remember.md (§11.4.131) — read it first.
2. **Continue the §11.4.126 autonomous hardening loop** (operator: "keep hardening, don't tag yet"). Base proxy UP :53128 (204); ~43% host; 4 helixproxy_* Podman secrets present. Keep dispatching 3–4 parallel non-data-plane subagents on remaining actionable items (§11.4.103); the data plane / :53128 has a single owner (§11.4.119) — coordinate before any boot.

3. **P10 fail-closed — GREEN + guarded (567c9e1).** Real-VPN-egress half remains operator-gated on gluetun WireGuard creds (§11.4.21/.66). To re-run fail-closed: 4 secrets from tests/observability/gen_test_mtls.sh → ./start --dynamic (backgrounded) → HELIX_DYNAMIC_STACK=1 ... bash tests/dynamic/vpn_failclosed_test.sh → restore base ./stop && ./start.
4. **LE — issuance + renewal BOTH PROVEN (autonomous scope COMPLETE).** Phase 3 hermetic DNS-01 issuance + Phase 5 zero-downtime renewal/rotation are cert-analyzer-verified, re-runnable, and guarded (tests/letsencrypt/phase3_issuance_guard.sh + phase5_rotation_guard.sh, wired in run-tests.sh); custom Caddy image via deploy/letsencrypt/build.sh; cert-analyzer self-test 37→55 (8833ccc). Phase 4 (LE-staging token §11.4.10)
 - Phase 6 (prod domain) OPERATOR-BLOCKED. Docs docs/design/letsencrypt/Status.md.
5. **Operator-gated queue (surface, don't autonomously break):** 2 TRACKED security items (Squid dns_nameservers DNS-leak, Dante client-side open-relay — both connectivity-risk §11.4.101); LE Phase 4/6; P10 real-egress (gluetun creds); HelixQA vendoring (6 un-vendored siblings, docs/helixqa/UNBLOCK.md); the release tag helix_proxy-0.1.0-dev-0.0.2 (operator said don't tag yet).
6. Every change: TDD reproduce-first (§11.4.43/§11.4.115), all warranted test types (§11.4.169), paired §1.1 mutation, independent review → iterate-to-GO (§11.4.142/§11.4.125/§11.4.134), docs in sync (§11.4.60/§11.4.65/§11.4.106), operator resources untouched (§11.4.174: wg0-mullvad, lava-*, whoami:58080).